

TP 3

Confinement des services et contrôle d'accès obligatoire

Modalité Travail en groupe de 2 ou 3 étudiants

Contexte et finalité

Vous allez confiner un service systemd, appliquer un profil AppArmor puis diagnostiquer un refus SELinux. Chaque manipulation compare une opération autorisée et une opération refusée afin d'identifier le contrôle responsable. La tâche autonome réutilise le lecteur AppArmor pour traiter un nouveau besoin d'accès.

Objectifs pédagogiques

- Restreindre les écritures et les privilèges d'un service sous un compte dédié.
- Valider un profil AppArmor par des tests et des traces corrélées.
- Corriger durablement un contexte SELinux et le distinguer des permissions DAC.
- Justifier en groupe une autorisation précise en maintenant des refus utiles.

Prérequis et environnement technique

- VM Ubuntu Server 24.04 LTS x86_64 et VM Rocky Linux 9 déjà installées, accessibles successivement ; AppArmor actif sur Ubuntu et SELinux enforcing sur Rocky.
- Compte avec sudo, console de l'hyperviseur, instantané initial et accès aux dépôts officiels. Installer les outils indiqués dans les étapes de préparation.
- VM isolées du réseau physique pour les services du TP, données fictives uniquement. Les commandes sont destinées à ces VM.

Travail demandé

Réalisez les manipulations guidées, répondez aux questions numérotées et conservez les preuves demandées. Traitez ensuite la tâche autonome et présentez vos résultats dans un rapport PDF. Les prolongements facultatifs ne sont pas évalués.

1 Environnements et outils de diagnostic

1.1 Préparation des machines virtuelles

Les deux VM sont déjà installées et accessibles par leur console. Prenez un instantané avant les essais. Ubuntu et Rocky sont utilisés successivement : les manipulations ne demandent aucune liaison réseau entre eux. Les seules installations demandées sont celles des outils ci-dessous et du serveur local de la section 6.

```
# VM Ubuntu 24.04
sudo apt update
sudo apt install -y build-essential apparmor apparmor-utils
mkdir -p ~/tp3
cd ~/tp3
cat /etc/os-release
uname -r
systemd --version
sudo aa-status
```

1.2 État des protections et périmètre des contrôles

AppArmor doit être actif. Un paquet installé ne prouve pas qu'une protection est appliquée. Toutes les données utilisées seront fictives et les services resteront limités aux VM du TP. Conservez uniquement les sorties utiles au diagnostic, avec la VM et la commande correspondantes.

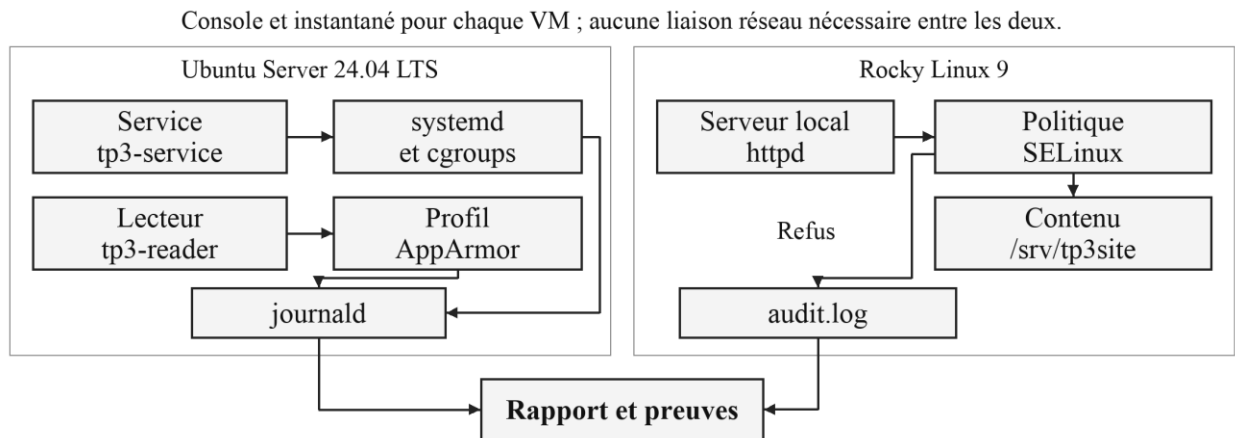


Figure 1. Deux environnements complémentaires pour comparer les mécanismes de confinement.

Q1 À partir de la figure, distinguez le rôle de systemd, d'AppArmor et de SELinux. Pourquoi le seul état « actif » d'un service ne démontre-t-il pas son confinement ?

2 Service témoin sous Ubuntu

2.1 Compte dédié et programme témoin

Le service écrit dans trois répertoires, puis attend. Les deux répertoires sous /srv ont les mêmes permissions DAC : cette symétrie permettra d'isoler l'effet du confinement systemd.

```
sudo useradd --system --user-group --no-create-home \  
  --shell /usr/sbin/nologin tp3svc  
sudo install -d -o tp3svc -g tp3svc -m 0750 \  
  /srv/tp3-exchange /srv/tp3-denied  
sudo install -d -m 0755 /usr/local/libexec  
sudo tee /usr/local/libexec/tp3-worker >/dev/null <<'EOF'  
#!/bin/sh  
for zone in /var/lib/tp3-service /srv/tp3-exchange /srv/tp3-denied  
do  
  if printf 'service actif\n' > "$zone/etat.txt"; then  
    printf 'OK %s\n' "$zone"  
  else  
    printf 'REFUS %s\n' "$zone"  
  fi  
done  
exec /usr/bin/sleep infinity  
EOF  
sudo chmod 0755 /usr/local/libexec/tp3-worker
```

2.2 Unité systemd et résultats de référence

```
sudo tee /etc/systemd/system/tp3-service.service >/dev/null <<'EOF'  
[Unit]  
Description=Service témoin du TP3  
[Service]  
User=tp3svc  
Group=tp3svc  
StateDirectory=tp3-service  
StateDirectoryMode=0750  
ExecStart=/usr/local/libexec/tp3-worker  
EOF  
sudo systemd-analyze verify /etc/systemd/system/tp3-service.service  
sudo systemctl daemon-reload  
sudo systemctl start tp3-service  
sudo journalctl -u tp3-service -n 12 --no-pager
```

Les trois écritures doivent réussir. StateDirectory crée /var/lib/tp3-service avec le propriétaire et le mode déclarés. Corrigez tout défaut du témoin avant la section suivante.

Q2 Pourquoi tp3svc peut-il exécuter ce service sans shell de connexion ? Quel intérêt présente le test de référence avant durcissement ?

3 Confinement systemd et privilèges

3.1 Configuration des restrictions

Ajoutez une surcharge [R1]. Le besoin fonctionnel autorise l'état interne et le répertoire d'échange, mais pas /srv/tp3-denied.

```
sudo mkdir -p /etc/systemd/system/tp3-service.service.d
sudo tee /etc/systemd/system/tp3-service.service.d/hardening.conf \
  >/dev/null <<'EOF'
[Service]
NoNewPrivileges=yes
CapabilityBoundingSet=
ProtectSystem=strict
ProtectHome=yes
PrivateTmp=yes
ReadWritePaths=/srv/tp3-exchange
SystemCallArchitectures=native
SystemCallFilter=@system-service
MemoryMax=96M
TasksMax=16
EOF
sudo systemctl daemon-reload
sudo systemctl restart tp3-service
sudo journalctl -u tp3-service -n 12 --no-pager
sudo -u tp3svc touch /srv/tp3-denied/hors-service.txt
TP3_PID=$(systemctl show -p MainPID --value tp3-service)
sudo awk '/^(Uid|CapEff|CapBnd|NoNewPrivs|Seccomp):/' \
  /proc/"$TP3_PID"/status
```

3.2 Interprétation des contrôles effectifs

Dans le service, l'état et l'échange restent accessibles en écriture ; le troisième chemin devient en lecture seule. Hors du service, touch réussit avec le même UID. StateDirectory fournit une exception gérée par systemd. ReadWritePaths ne contourne ni le DAC ni une politique MAC.

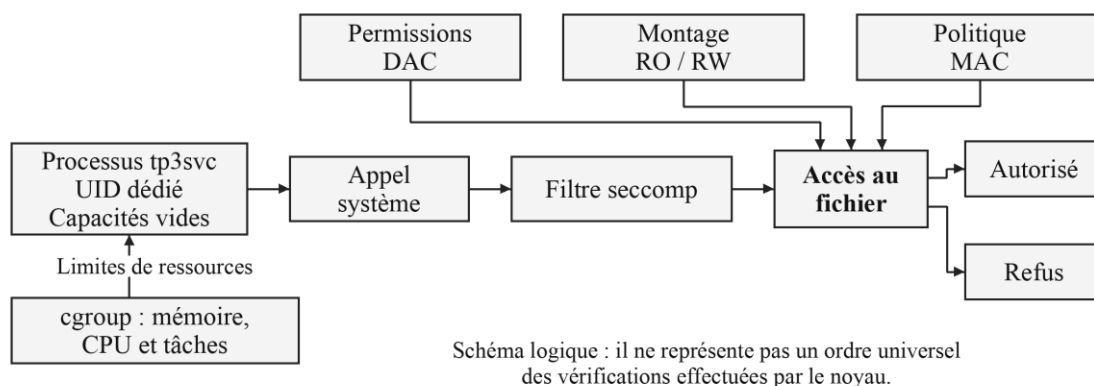


Figure 2. Plusieurs conditions indépendantes doivent autoriser l'opération demandée.

Q3 Expliquez ces résultats différents pour le même UID. Distinguez NoNewPrivileges, la borne de capacités et Seccomp=2 : cette dernière valeur prouve-t-elle qu'un appel précis a été refusé [R3, R4] ?

P1 Preuve à conserver Journaux avant/après, surcharge finale et extrait /proc. Pour les trois chemins, résumez les résultats attendus et observés ; joignez le témoin hors service.

4 Lecteur dédié à AppArmor

4.1 Compilation et installation du lecteur

Ce petit programme lit un fichier donné en argument. Un binaire dédié évite de confiner un interpréteur partagé. Les trois fichiers ont volontairement des permissions DAC identiques et ne contiennent aucun secret réel.

```
cd ~/tp3
cat > tp3-reader.c <<'EOF'
#include <stdio.h>
int main(int argc, char **argv) {
    if (argc != 2) return 2;
    FILE *f = fopen(argv[1], "r");
    if (f == NULL) { perror(argv[1]); return 1; }
    int c;
    while ((c = fgetc(f)) != EOF) putchar(c);
    int failed = ferror(f);
    fclose(f);
    return failed ? 1 : 0;
}
EOF
cc -Wall -Wextra -O2 tp3-reader.c -o tp3-reader
sudo install -m 0755 tp3-reader /usr/local/bin/tp3-reader
```

4.2 Jeu de données et lectures de référence

```
for zone in public restricted private; do
    sudo install -d -m 0755 "/srv/tp3-aa/$zone"
    printf 'Donnee fictive : %s\n' "$zone" | \
        sudo tee "/srv/tp3-aa/$zone/info.txt" >/dev/null
    sudo chmod 0644 "/srv/tp3-aa/$zone/info.txt"
done
for zone in public restricted private; do
    /usr/local/bin/tp3-reader "/srv/tp3-aa/$zone/info.txt"
    printf 'retour=%s\n' "$?"
done
```

Les trois lectures doivent réussir avant chargement du profil. En cas d'échec, vérifiez les chemins et les permissions des répertoires parents. Conservez ces résultats de référence pour P2. Il n'est pas demandé d'analyser le langage C : son rôle est de fournir une sonde minimale et reproductible.

4.3 Répartition et vérification croisée

Un membre réalise la préparation ; un autre vérifie les trois lectures et l'absence de profil antérieur portant le même nom. Échangez ensuite les rôles pour l'application et le diagnostic de la politique.

5 Politique AppArmor et contrôle des accès

5.1 Définition et chargement du profil

Le profil est attaché au chemin du binaire. Il autorise public, ne prévoit pas restricted et interdit explicitement private avec journalisation [R5].

```
sudo tee /etc/apparmor.d/usr.local.bin.tp3-reader >/dev/null <<'EOF'
#include <tunables/global>
profile tp3-reader /usr/local/bin/tp3-reader {
  #include <abstractions/base>
  /usr/local/bin/tp3-reader mr,
  /srv/tp3-aa/public/** r,
  audit deny /srv/tp3-aa/private/** r,
}
EOF
sudo apparmor_parser -r /etc/apparmor.d/usr.local.bin.tp3-reader
sudo aa-enforce /usr/local/bin/tp3-reader
sudo aa-status
for zone in public restricted private; do
  /usr/local/bin/tp3-reader "/srv/tp3-aa/$zone/info.txt"
  printf 'retour=%s\n' "$?"
done
cat /srv/tp3-aa/private/info.txt
sudo journalctl -k --since '-5 min' --no-pager \
  --grep='apparmor=. *tp3-reader'
```

5.2 Analyse des accès et des traces

Chemin	Résultat attendu	Cause à vérifier
public/info.txt	Lecture autorisée	Autorisation de lecture
restricted/info.txt	Lecture refusée	Autorisation absente
private/info.txt	Lecture refusée par le lecteur	Interdiction explicite auditée

Dans les traces, retrouvez le profil, le chemin et l'opération refusée. Si auditd reçoit ces événements, consultez /var/log/audit/audit.log. La lecture directe par cat sert de comparaison : ce programme n'est pas attaché au profil tp3-reader.

Q4 Le profil protège-t-il ces fichiers contre tous les programmes ? D'après les manuels [R5, R8], lequel des deux refus resterait applicable en mode complain, et pourquoi ? Ne changez pas de mode pour cette question.

P2 Preuve à conserver Profil final, trois tests avec codes de retour, comparaison avec cat et deux traces de refus expliquées. Un autre membre reproduit un cas autorisé et un cas refusé.

6 Refus SELinux sur Rocky Linux

6.1 Serveur local et type volontairement erroné

Utilisez la VM Rocky Linux 9 avec SELinux Enforcing. Le serveur reste sur la boucle locale. Le type erroné `default_t` est affecté uniquement au contenu fictif du scénario [R6, R7].

```
sudo dnf install -y httpd polycoreutils-python-utils audit curl
getenforce
sudo systemctl start auditd
sudo install -d -m 0755 /srv/tp3site
printf 'Portail TP3 disponible\n' | \
  sudo tee /srv/tp3site/index.html >/dev/null
sudo chmod 0644 /srv/tp3site/index.html
sudo sed -i -E 's/^Listen[[:space:]]+80$/Listen 127.0.0.1:80/' \
  /etc/httpd/conf/httpd.conf
sudo tee /etc/httpd/conf.d/tp3site.conf >/dev/null <<'EOF'
<VirtualHost 127.0.0.1:80>
  ServerName tp3.local
  DocumentRoot /srv/tp3site
  <Directory /srv/tp3site>
    Require all granted
    Options -Indexes
    AllowOverride None
  </Directory>
</VirtualHost>
EOF
sudo chcon -R -t default_t /srv/tp3site
sudo httpd -t
sudo systemctl start httpd
sudo ss -ltnp '( sport = :80 )'
curl -sS -o /dev/null -w '%{http_code}\n' \
  http://127.0.0.1/index.html
sudo ausearch -m AVC,USER_AVC -ts recent -i
```

6.2 Identification du refus et analyse de l'AVC

Si l'écoute n'est pas exclusivement 127.0.0.1:80, arrêtez httpd et corrigez Listen. Un refus HTTP seul ne prouve pas l'intervention de SELinux : il faut un AVC corrélié au test. En l'absence de trace, vérifiez auditd et rejouez la requête ; gardez SELinux enforcing.

Q5 Dans l'AVC, identifiez `scontext`, `tcontext`, `tclass` et la permission refusée. Pourquoi un cat exécuté sous l'UID apache ne reproduit-il pas nécessairement le domaine `httpd_t` ?

7 Contextes SELinux persistants et permissions DAC

7.1 Association persistante entre chemin et type

```
ps -eZ | grep '[h]ttpd'
ls -ldZ /srv/tp3site /srv/tp3site/index.html
namei -l /srv/tp3site/index.html
sudo semanage fcontext -a -t httpd_sys_content_t '/srv/tp3site(/.*)?'
sudo restorecon -Rv /srv/tp3site
matchpathcon -V /srv/tp3site/index.html
curl -sS -i http://127.0.0.1/index.html
```

La page doit maintenant être accessible. semanage enregistre l'association persistante entre chemin et type ; restorecon l'applique aux fichiers. Un simple chcon ne définit pas cette association.

P3 Preuve à conserver AVC initial annoté, domaine du serveur, types avant/après, association semanage et réponse HTTP après correction. Expliquez le changement causal.

7.2 Distinction entre contrôle DAC et contrôle MAC

```
sudo chmod 0600 /srv/tp3site/index.html
curl -sS -o /dev/null -w '%{http_code}\n' \
http://127.0.0.1/index.html
ls -lZ /srv/tp3site/index.html
sudo tail -n 8 /var/log/httpd/error_log
sudo chmod 0644 /srv/tp3site/index.html
sudo chcon -t default_t /srv/tp3site/index.html
matchpathcon -V /srv/tp3site/index.html
sudo restorecon -v /srv/tp3site/index.html
curl -sS -i http://127.0.0.1/index.html
```

Le chmod 0600 provoque un refus DAC malgré le type correct. Après remise des permissions, la seconde altération du type est corrigée par restorecon grâce à l'association enregistrée. Un changement chcon peut survivre à un redémarrage ; une opération de réétiquetage peut le remplacer.

7.3 Démarche de diagnostic et preuves

Q6 Que modifient chmod, chcon, semanage fcontext et restorecon ? Pourquoi un module produit immédiatement avec audit2allow serait-il une correction inadaptée de ce mauvais type ?

Q7 Établissez une démarche de diagnostic d'un accès refusé à partir de la figure 2. Pourquoi l'absence d'AVC ne suffit-elle pas à prouver l'absence de contrôle MAC ?

P4 Preuve à conserver Refus DAC avec type correct, permissions restaurées et réussite après le restorecon final. Distinguez ce refus de celui observé en section 6.

8 Tâche autonome

8.1 Autorisation d'un nouveau fichier précis

Une nouvelle donnée validée doit devenir lisible par tp3-reader sous Ubuntu. Réutilisez le lecteur et son profil. Vous pouvez consulter la documentation. Le chemin de cette donnée sera /srv/tp3-aa/valide/resultat.txt. Aucun nouveau service ni seconde installation ne sont demandés.

Critère	Résultat et preuve attendus
A1 Accès nécessaire	Créer une donnée fictive au chemin demandé et adapter le profil pour autoriser ce fichier précis. Montrer sa lecture et celle de public/info.txt.
A2 Refus maintenus	Créer un autre fichier lisible selon le DAC dans le même répertoire valide. Sa lecture par tp3-reader doit échouer, ainsi que celle de private/info.txt. Conserver une trace corrélée à un refus.
A3 Justification et contrôle croisé	Garder le profil en enforce. Un autre membre reproduit un cas positif et un cas négatif. Expliquer en quelques lignes le choix du motif de chemin et la limite révélée par une lecture directe avec cat.

Aucune suite de commandes n'est fournie pour cette tâche. Remettez dans le rapport le seul extrait du profil modifié et une matrice des quatre accès attendus/observés. Un fichier de configuration créé peut être joint séparément si utile.

8.2 Synthèse et remise en état

Pour la synthèse du rapport, choisissez les preuves P1 à P4 et A1 à A3, répondez brièvement à Q1 à Q7 et indiquez une limite des protections. Conservez votre rapport et les éventuelles pièces jointes hors des VM avant leur restauration.

```
# Ubuntu, apres conservation des resultats
sudo systemctl stop tp3-service
# Rocky Linux, apres conservation des resultats
sudo systemctl stop httpd
```

Restaurez ensuite les instantanés initiaux. N'utilisez jamais l'arrêt d'une protection comme correction d'un accès refusé.

8.3 Prolongements facultatifs non évalués

- Comparer enforce et complain sur les deux refus AppArmor, puis revenir en enforce [R8]. Expliquer pourquoi un deny explicite reste applicable.
- Observer les valeurs cgroups de memory.max et pids.max du service [R2]. Étudier le principe d'une sonde seccomp inoffensive [R4], sans essai d'épuisement de ressources.

9 Rapport et évaluation

9.1 Consignes de rendu

Remettez un seul rapport PDF par groupe de 2 ou 3 étudiants. Répartissez puis alternez les rôles de réalisation, de vérification et de rédaction. Tous les membres doivent pouvoir expliquer les résultats.

Le rapport comprend les réponses numérotées, les preuves sélectionnées et le résultat de la tâche autonome. Les scripts ou configurations créés peuvent être joints séparément si leur contenu est utile. Aucune archive ni organisation en dossiers n'est demandée.

Ne joignez aucun mot de passe, clé privée, jeton, en-tête LUKS ou donnée personnelle réelle.

9.2 Résultats des manipulations guidées

Chaque preuve associe la commande ou la configuration, un résultat lisible et une courte interprétation. Expliquez également les refus attendus. Rédigez au fil des manipulations et retenez uniquement les extraits utiles.

Preuve	Contenu attendu
P1	Service avant/après, matrice des écritures et privilèges effectifs
P2	Profil AppArmor, lectures autorisées/refusées et traces
P3	AVC initial et correction persistante du type SELinux
P4	Distinction d'un refus DAC et reprise après restorecon

9.3 Tâche autonome et synthèse

- A1 : lecture de la nouvelle donnée précise et maintien de l'accès public.
- A2 : deux refus maintenus et une trace corrélée.
- A3 : profil enforce, vérification croisée et justification concise.

Concluez par une limite observée et une amélioration justifiée. Signalez tout test non réalisé et son blocage. Une capture de statut ou un score d'audit sans analyse ne suffit pas.

9.4 Critères d'évaluation

Critère	Points
Manipulations guidées et preuves exploitables	7
Réponses argumentées et diagnostic	4
Tâche autonome et tests des exigences	6
Clarté et rigueur du rapport	3
Total	20

10 Références techniques

Ces références complètent les manuels installés dans les VM. Vérifiez les options dans la version locale avant de transposer une configuration. La recherche documentaire est autorisée, y compris pour la tâche autonome. Citez les ressources utilisées et expliquez leur adaptation.

Les figures de cet énoncé sont des schémas pédagogiques originaux.

R1 Ubuntu 24.04 : systemd.exec, environnement d'exécution et confinement

<https://manpages.ubuntu.com/manpages/noble/en/man5/systemd.exec.5.html>

R2 Ubuntu 24.04 : systemd.resource-control, contrôle des ressources

<https://manpages.ubuntu.com/manpages/noble/en/man5/systemd.resource-control.5.html>

R3 Documentation du noyau Linux : No New Privileges Flag

https://docs.kernel.org/userspace-api/no_new_privs.html

R4 Documentation du noyau Linux : Seccomp BPF

https://docs.kernel.org/userspace-api/seccomp_filter.html

R5 Ubuntu 24.04 : apparmor.d, syntaxe des profils de sécurité

<https://manpages.ubuntu.com/manpages/noble/en/man5/apparmor.d.5.html>

R6 Red Hat Enterprise Linux 9 : Using SELinux, contextes et diagnostic

https://docs.redhat.com/en/documentation/red_hat_enterprise_linux/9/html-single/using_selinux/index

R7 Rocky Linux : SELinux Security

https://docs.rockylinux.org/guides/security/learning_selinux/

R8 Ubuntu 24.04 : aa-complain et portée des interdictions explicites

<https://manpages.ubuntu.com/manpages/noble/en/man8/aa-complain.8.html>